Insper

Cybersegurança em nuvem

Prof. Dr. Rodolfo Avelino

Caso Maisplace

1. Contexto da empresa

Fundada em 2012, a **MaisPlace** é uma empresa brasileira de comércio eletrônico que comercializa produtos para casa, eletrônicos, acessórios e itens de uso pessoal.

A empresa iniciou suas atividades como uma pequena operação de vendas pela Internet e apresentou crescimento significativo nos últimos anos. Atualmente possui aproximadamente **120 colaboradores**, distribuídos entre as áreas comercial, marketing, atendimento ao cliente, financeiro, tecnologia e operações.

Sua sede administrativa está localizada no mesmo complexo de seu principal centro de distribuição.

A operação da empresa depende fortemente de sua plataforma digital. Praticamente todo o faturamento tem origem no comércio eletrônico e os pedidos realizados pelos clientes alimentam os processos de pagamento, separação de mercadorias, emissão de documentos fiscais, expedição e atendimento pós-venda.

Uma indisponibilidade prolongada da plataforma, portanto, não representa apenas um problema de tecnologia: pode interromper parte significativa da operação da empresa.

2. A plataforma de comércio eletrônico

Desde o início das operações, a MaisPlace utiliza uma plataforma de comércio eletrônico baseada em **WooCommerce**.

A solução foi inicialmente instalada e configurada por um funcionário que, durante os primeiros anos da empresa, acumulava responsabilidades de desenvolvimento, infraestrutura e suporte.

Ao longo do tempo, novas funcionalidades foram incorporadas à plataforma para atender às necessidades do negócio.

Insper

Atualmente, o ambiente possui integrações com:

- meios de pagamento;
- sistema de gestão empresarial;
- controle de estoque;
- emissão de documentos fiscais;
- transportadoras;
- ferramentas de marketing;
- serviços de atendimento aos clientes.

Diversos plugins também foram adicionados ao WooCommerce ao longo dos anos.

Parte dessas integrações foi desenvolvida especificamente para a MaisPlace e possui documentação limitada.

3. Estrutura da equipe de TI

A equipe formal de TI começou a ser estruturada há aproximadamente dois anos.

Atualmente, ela é responsável por:

- suporte aos funcionários;
- manutenção da infraestrutura;
- administração dos servidores;
- redes;
- contas de usuários;
- suporte à plataforma de comércio eletrônico;
- relacionamento com fornecedores de tecnologia.

A equipe de desenvolvimento também possui acesso a determinados recursos da infraestrutura para realizar atualizações e solucionar problemas da plataforma.

Como a operação de comércio eletrônico funciona continuamente, problemas críticos precisam ser solucionados rapidamente.

Em diversas situações, os profissionais envolvidos recebem privilégios elevados para evitar atrasos durante a resolução de incidentes.

Não existe atualmente uma área dedicada exclusivamente à segurança da informação ou cybersegurança.

Insper

4. Crescimento e problemas recentes

Nos últimos dois anos, o volume de vendas cresceu significativamente.

Durante campanhas promocionais, a quantidade de acessos pode aumentar várias vezes em poucas horas.

A infraestrutura atual começou a apresentar dificuldades para acompanhar esse crescimento.

Nos últimos doze meses ocorreram alguns episódios que chamaram a atenção da diretoria.

Incidente 1 — Indisponibilidade durante campanha

Durante uma campanha promocional, a plataforma ficou indisponível por aproximadamente duas horas.

Clientes relataram dificuldades para finalizar compras e o atendimento recebeu um grande número de reclamações.

A equipe conseguiu restabelecer o serviço, mas não conseguiu determinar com precisão o que havia provocado a indisponibilidade.

Incidente 2 — Conta administrativa

Em outra ocasião, uma conta com privilégios administrativos foi utilizada durante a madrugada.

Nenhum integrante da equipe confirmou ter realizado o acesso.

Como medida preventiva, a senha da conta foi alterada.

Entretanto, devido à quantidade limitada de registros disponíveis, não foi possível determinar com segurança quais atividades foram executadas utilizando aquela conta.

Insper

Incidente 3 — Alteração após atualização

Após uma atualização de componentes da plataforma, alguns clientes encontraram dificuldades para concluir pedidos.

A equipe precisou realizar alterações diretamente no ambiente de produção para restabelecer o funcionamento.

O incidente ocorreu durante horário comercial.

5. A decisão de migrar para cloud computing

Diante do crescimento da operação e das limitações da infraestrutura atual, a diretoria aprovou a migração da plataforma para **Amazon Web Services — AWS**.

A migração é considerada estratégica para a empresa.

A expectativa da diretoria é que o novo ambiente permita:

- suportar o crescimento do negócio;
- aumentar a disponibilidade da plataforma;
- melhorar a capacidade de recuperação diante de falhas;
- aumentar a segurança;
- facilitar futuras expansões da operação.

Entretanto, os incidentes recentes reduziram a confiança da diretoria na capacidade da empresa de identificar e administrar riscos tecnológicos.

Durante uma reunião sobre a migração, um dos diretores afirmou:

“Se vamos colocar tudo na AWS, boa parte dos problemas de segurança atuais deixa de ser nossa responsabilidade.”

Outro diretor questionou essa afirmação:

“Mas se alguém roubar uma conta administrativa, explorar nossa aplicação ou acessar os dados dos clientes, quem será responsável?”

A equipe não apresentou uma resposta consensual.

Insper

Diante da discussão, o presidente determinou que a migração deverá ser precedida por uma **análise dos riscos cibernéticos** existentes.

O objetivo é evitar que a empresa simplesmente transfira para a nuvem os mesmos problemas presentes no ambiente atual.

6. Informações tratadas pela plataforma

Durante o levantamento inicial, foram identificadas diferentes categorias de informações processadas pela plataforma.

Entre elas estão:

- dados cadastrais dos clientes;
- nomes;
- endereços;
- telefones;
- e-mails;
- histórico de pedidos;
- informações sobre produtos e preços;
- informações relacionadas a estoque;
- registros de atendimento;
- informações necessárias às integrações com parceiros e fornecedores;
- credenciais utilizadas por aplicações e integrações.

A equipe informou que os pagamentos são processados por empresas especializadas e que a MaisPlace **não pretende armazenar diretamente números completos de cartões de crédito**.

Mesmo assim, a plataforma participa do fluxo necessário para iniciar e confirmar as transações.

7. Levantamento preliminar de ameaças

Há aproximadamente dois anos, a equipe realizou um levantamento de ameaças observadas em empresas do mesmo segmento.

O levantamento encontrou as seguintes categorias:

.

Insper

Ameaça	Descrição
Insider	Funcionários ou terceiros utilizando seus acessos, intencionalmente ou não, de maneira capaz de comprometer os recursos ou informações da empresa.
Malware	Ransomware e outros códigos maliciosos capazes de comprometer aplicações, servidores, estações ou informações.
Denial of Service	Ataques DoS ou DDoS capazes de comprometer a disponibilidade da plataforma de vendas.
Ataques contra aplicações Web	Exploração de vulnerabilidades da aplicação, plugins, APIs ou outros componentes disponibilizados pela plataforma.
Comprometimento de credenciais	Obtenção e utilização indevida de credenciais pertencentes a usuários, administradores ou serviços.
Comprometimento de informações	Acesso, alteração, destruição ou divulgação não autorizada de informações corporativas ou de clientes.

Esse levantamento não é considerado definitivo.

Como ele foi produzido anteriormente ao projeto de migração, a equipe deverá verificar:

- quais ameaças continuam relevantes;
- se existem ameaças que não foram consideradas;
- quais delas podem assumir maior importância no ambiente cloud.

Insper

8. Levantamento do ambiente atual

Como parte da preparação para a migração, foram realizadas entrevistas com profissionais das equipes de TI e desenvolvimento.

Foram identificadas as seguintes situações.

8.1 Contas administrativas

A administração dos servidores é realizada utilizando contas com privilégios elevados.

Algumas atividades são executadas utilizando contas administrativas conhecidas por mais de um profissional.

Segundo a equipe, essa prática facilita o atendimento de problemas urgentes.

Não existe processo periódico para verificar quais profissionais ainda necessitam dos privilégios concedidos.

8.2 Autenticação

O acesso administrativo a parte dos sistemas utiliza apenas usuário e senha.

Não existe obrigatoriedade de autenticação multifator para todos os acessos administrativos.

As regras utilizadas para criação e alteração de senhas não são uniformes entre os diferentes componentes do ambiente.

8.3 Atualizações e vulnerabilidades

Não existe um processo formal de gestão de vulnerabilidades.

Atualizações do sistema operacional e dos componentes da plataforma são realizadas quando a equipe identifica necessidade.

O WooCommerce e seus plugins também precisam ser atualizados periodicamente.

Alguns plugins foram instalados há vários anos.

Durante o levantamento, a equipe não conseguiu confirmar imediatamente:

- quais plugins ainda são necessários;
- quem é responsável por cada componente;
- quando cada componente foi atualizado pela última vez;
- se existem vulnerabilidades conhecidas associadas às versões utilizadas.

8.4 Aplicação e banco de dados

A aplicação e o banco de dados possuem poucas restrições de comunicação entre seus componentes.

Historicamente, a arquitetura foi desenvolvida priorizando simplicidade operacional.

A equipe reconhece que a migração representa uma oportunidade para revisar essa arquitetura, mas ainda não definiu como os componentes deverão ser distribuídos no novo ambiente.

8.5 Rede

As regras de comunicação entre sistemas foram criadas gradualmente à medida que novas necessidades surgiram.

Algumas regras permitem comunicação mais ampla do que a equipe considera necessária atualmente.

Não existe documentação completa justificando todas as regras existentes.

8.6 Administração remota

Profissionais da equipe precisam realizar atividades administrativas fora do escritório, especialmente durante campanhas promocionais ou incidentes.

Os mecanismos utilizados para esse acesso foram implantados em diferentes momentos e não existe atualmente um padrão único para administração remota dos recursos.

Insper

8.7 Credenciais de aplicações e integrações

A plataforma precisa utilizar diferentes credenciais para se comunicar com sistemas internos e serviços externos.

Durante o levantamento foram encontrados arquivos de configuração contendo:

- usuários;
- senhas;
- tokens;
- chaves utilizadas por integrações.

A equipe informou que alguns desses arquivos são necessários para facilitar a implantação e manutenção das aplicações.

Não existe um inventário centralizado dessas credenciais nem um processo uniforme para sua substituição periódica.

8.8 Logs

Os sistemas geram registros de diferentes tipos.

Entretanto, os logs encontram-se distribuídos entre servidores e aplicações.

Normalmente eles são consultados quando a equipe já sabe que existe um problema.

Não existe uma visão centralizada que permita acompanhar atividades administrativas e eventos relevantes de segurança.

Essa situação contribuiu para a dificuldade de investigação do acesso administrativo ocorrido durante a madrugada.

8.9 Monitoramento

A equipe possui mecanismos básicos para verificar se determinados servidores estão funcionando.

Entretanto, o monitoramento está concentrado principalmente em disponibilidade.

Não existem procedimentos definidos para detectar comportamentos suspeitos, alterações administrativas incomuns ou possíveis tentativas de ataque contra a plataforma.

8.10 Backup e recuperação

Backups do banco de dados são executados periodicamente.

A equipe conseguiu demonstrar que os arquivos de backup são gerados.

Entretanto, não foram apresentados registros recentes de um teste completo de recuperação da plataforma utilizando esses backups.

Alguns integrantes da equipe acreditam que a utilização da AWS reduzirá significativamente a necessidade de preocupação com esse problema devido à redundância disponível na infraestrutura cloud.

8.11 Desenvolvimento, homologação e produção

A equipe precisa realizar alterações frequentes na plataforma.

Existe um ambiente utilizado para desenvolvimento e testes, porém algumas correções urgentes acabam sendo realizadas diretamente em produção.

Os critérios para acesso aos diferentes ambientes não estão formalmente definidos.

Durante a migração para AWS, será necessário decidir como desenvolvimento, testes, homologação e produção deverão ser organizados.

8.12 Terceiros

A MaisPlace utiliza empresas externas para suporte de alguns componentes da plataforma.

Em determinadas situações, técnicos externos recebem acesso ao ambiente para diagnóstico e correção de problemas.

Esses acessos são concedidos pela equipe de TI conforme a necessidade.

Não existe processo formal de revisão periódica dos acessos concedidos a terceiros.

Insper

8.13 Documentação e inventário

Não existe um inventário único e atualizado contendo todos os componentes utilizados pela plataforma.

Parte do conhecimento sobre configurações, integrações e dependências encontra-se com profissionais específicos da equipe.

Essa situação preocupa a diretoria porque alguns dos componentes foram implantados por pessoas que não trabalham mais na empresa.

8.14 Resposta a incidentes

Quando ocorre um incidente, os profissionais disponíveis procuram identificar o problema e restabelecer o serviço.

Não existe um plano formal de resposta a incidentes estabelecendo:

- responsáveis;
- critérios de escalonamento;
- procedimentos de contenção;
- preservação de evidências;
- comunicação com a diretoria;
- comunicação com clientes e parceiros;
- atividades posteriores ao incidente.

9. O novo ambiente

A diretoria determinou que a nova plataforma deverá ser implementada na **AWS**.

Cada equipe responsável pelo projeto receberá um **domínio válido** para publicação da aplicação.

A empresa também definiu alguns requisitos mínimos para a solução.

A plataforma deverá:

- ser acessível utilizando o domínio disponibilizado;
- utilizar comunicação HTTPS para os serviços Web disponibilizados aos usuários;

- possuir uma camada de proteção para o tráfego destinado à aplicação;
- utilizar **Cloudflare** ou uma solução baseada em serviços AWS para DNS e proteção da aplicação;
- possuir mecanismos de controle de identidade e acesso;
- registrar eventos relevantes para administração e segurança;
- possuir mecanismos de monitoramento;
- possuir estratégia de backup e recuperação;
- evitar exposição desnecessária de componentes internos à Internet.

Esses requisitos representam apenas um **baseline mínimo**.

A equipe responsável pela migração deverá determinar quais outros controles são necessários a partir da análise de riscos.

A diretoria não definiu previamente:

- quais serviços AWS deverão ser utilizados;
- como a rede deverá ser segmentada;
- onde a aplicação deverá ser executada;
- onde os dados deverão ser armazenados;
- quais componentes poderão ser acessados pela Internet;
- como os administradores acessarão o ambiente;
- como as credenciais das aplicações serão protegidas;
- como serão realizados logging e monitoramento;
- como serão implementados backup e recuperação.

Essas decisões fazem parte do projeto.

10. Primeira etapa — Análise de riscos

Antes da implementação do novo ambiente, a equipe deverá realizar uma análise dos riscos cibernéticos da MaisPlace.

10.1 Identificação

Identifique:

- ativos e processos relevantes;
- ameaças;
- vulnerabilidades;

- possíveis eventos de risco;
- consequências para o negócio.

Não se limite às ameaças apresentadas no levantamento preliminar.

11. Segunda etapa — Projeto da arquitetura AWS

Depois da análise de riscos, a equipe deverá projetar o novo ambiente.

As decisões arquiteturais deverão ser justificadas pelos riscos identificados.

Para os principais controles, deverá existir rastreabilidade:

Risco → Requisito de segurança → Controle → Implementação → Evidência

Por exemplo, não é suficiente afirmar:

“Utilizamos um firewall.”

A equipe deverá explicar:

- qual risco levou à necessidade desse controle;
- o que precisa ser protegido;
- como o controle foi configurado;
- qual tráfego é permitido;
- qual tráfego é bloqueado;
- como será possível verificar se o controle está funcionando.

12. Arquitetura

A equipe deverá produzir um diagrama da arquitetura proposta.

O diagrama deverá permitir identificar:

- Internet;
- domínio e resolução DNS;
- camada de proteção Web;
- utilização de HTTPS/TLS;
- pontos de entrada do ambiente;
- componentes públicos;

- componentes privados;
- aplicação;
- armazenamento de dados;
- principais fluxos de comunicação;
- acessos administrativos;
- integrações externas;
- mecanismos de logging;
- mecanismos de monitoramento;
- mecanismos de backup e recuperação.

O grupo deverá ser capaz de justificar **por que cada componente está localizado naquele ponto da arquitetura e quais comunicações são realmente necessárias**.

13. Terceira etapa — Implementação

Após a aprovação da arquitetura, o grupo deverá implementar o ambiente proposto na AWS.

A implementação deverá refletir as decisões tomadas durante a análise de riscos.

A utilização de um serviço ou produto de segurança, isoladamente, não será considerada evidência de que determinado risco foi tratado.

O grupo deverá demonstrar sua **configuração e funcionamento**.

14. Apresentação técnica e demonstração

Ao final da implementação, o grupo deverá realizar uma apresentação técnica demonstrando o ambiente construído.

A apresentação deverá responder:

1. Qual arquitetura foi implementada?
2. Quais riscos influenciaram as principais decisões arquiteturais?
3. Quais controles foram implementados?
4. Como esses controles foram configurados?
5. Quais evidências demonstram seu funcionamento?

Insper

6. Quais riscos permanecem?
7. O que seria implementado em uma próxima etapa caso a arquitetura fosse utilizada em produção?

O objetivo não é utilizar a maior quantidade possível de serviços AWS.

O objetivo é demonstrar que a equipe consegue transformar:

risco de negócio → requisito de segurança → arquitetura → configuração → evidência.